ETSI Security Conference 2025

# Advancing Vulnerability Assessment

Presented by: François Ambrosini

09/10/2025



TLP:CLEAR

# Advancing Vulnerability Assessment



HUAWEI

TLP:CLEAR



# CONTENTS


01. Vulnerability Risk Assessment

02 . AI Vulnerability Assessment

03 Takeaway and Next Step


HUAWEI

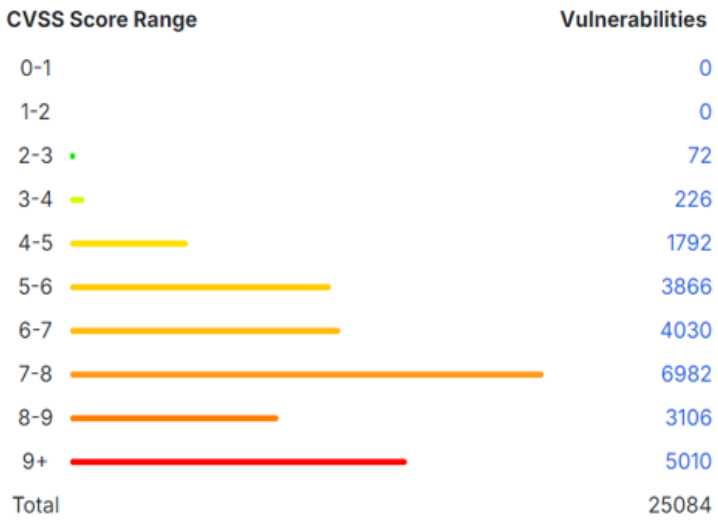
TLP:CLEAR

# Statistics of Vulnerability Disclosure in CVE from 2022 to 2024

## Industry resources are focused to prioritize Exploited vulnerability

- **Key trend**: the quantity of newly disclosed vulnerabilities is increasing year over year, it is necessary to establish a vulnerability management mechanism and improve vulnerability handling efficiency.
- **Key fact**: the quantity of vulnerabilities exploited each year is about 0.5% of disclosed vulnerabilities, these vulnerabilities need to be mitigated in a timely manner.

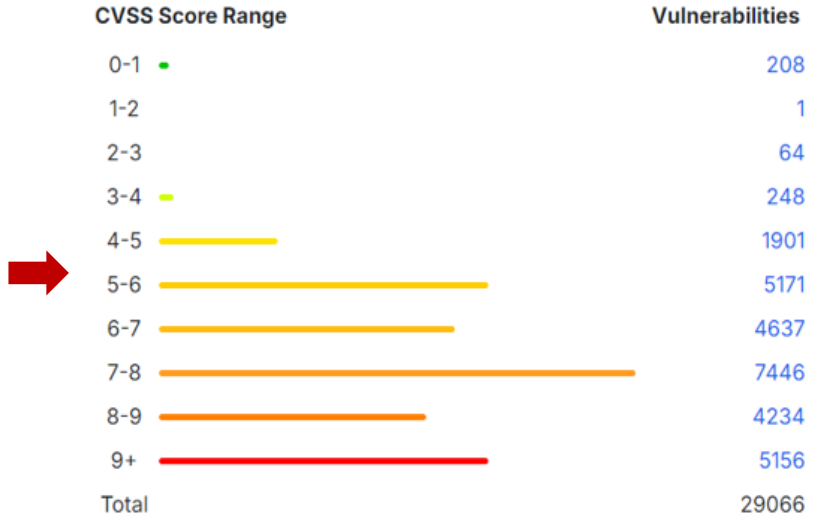
### Vulnerabilities disclosed in 2022



| CVSS Score Range | Vulnerabilities |
|---|---|
| 0-1 | 0 |
| 1-2 | 0 |
| 2-3 | 72 |
| 3-4 | 226 |
| 4-5 | 1792 |
| 5-6 | 3866 |
| 6-7 | 4030 |
| 7-8 | 6982 |
| 8-9 | 3106 |
| 9+ | 5010 |
| Total | 25084 |

- Total vulnerabilities 25084
- Known Exploited Vulnerabilities 127
- Exploited vulnerability ratio 0.51%

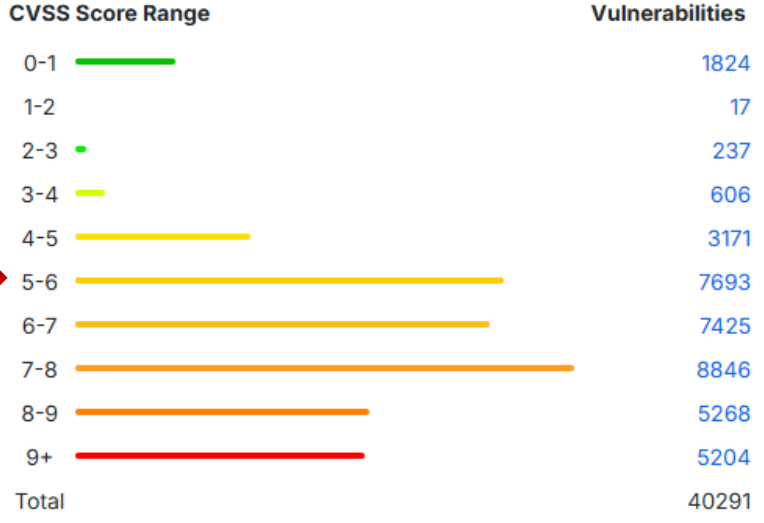
### Vulnerabilities disclosed in 2023



| CVSS Score Range | Vulnerabilities |
|---|---|
| 0-1 | 208 |
| 1-2 | 1 |
| 2-3 | 64 |
| 3-4 | 248 |
| 4-5 | 1901 |
| 5-6 | 5171 |
| 6-7 | 4637 |
| 7-8 | 7446 |
| 8-9 | 4234 |
| 9+ | 5156 |
| Total | 29066 |

- Total vulnerabilities 29066
- Known Exploited Vulnerabilities 150
- Exploited vulnerability ratio 0.52%

### Vulnerabilities disclosed in 2024



| CVSS Score Range | Vulnerabilities |
|---|---|
| 0-1 | 1824 |
| 1-2 | 17 |
| 2-3 | 237 |
| 3-4 | 606 |
| 4-5 | 3171 |
| 5-6 | 7693 |
| 6-7 | 7425 |
| 7-8 | 8846 |
| 8-9 | 5268 |
| 9+ | 5204 |
| Total | 40291 |

- Total vulnerabilities 40291
- Known Exploited Vulnerabilities 186
- Exploited vulnerability ratio 0.46%

*Source: https://www.cvedetails.com/*

TLP:CLEAR

# Risk-based vulnerability management is at the core of EU regulations

## All stakeholders are involved

**Radio Equipment Directive**

**Standardisation Request for Article 3(3)(d,e,f):** 2.1 (d) [radio equipment] are provided, on a risk basis, with up-to-date software and hardware at the moment of placing on the market **that do not contain publicly known exploitable vulnerabilities** […]

**NIS2 Directive**

**Article 21 (2)**: Cybersecurity **risk-management measures** covering
(e) security in network and information systems acquisition, development and maintenance, including **vulnerability handling and disclosure**;

**NIS2 Implementing Act (Annex)**

**Clause 2.1.2 point (e)**: analyse the **risks posed to the security of network and information systems**, including threat, likelihood, impact, and risk level, taking into account cyber threat intelligence and **vulnerabilities**;

**Clause 6.10.2 point (d):** ensure that their **vulnerability handling is compatible** with their change management, security patch management, **risk management** and incident management procedures;

**Cyber Resilience Act**

**Article 14 (1)**: vendors must **notify any actively exploited vulnerability** affecting their products that they become aware of [to the CSIRT and ENISA]

**ANNEX I Part I point (2)(a):** on the basis of the cybersecurity risk assessment referred to in Article 13(2) and where applicable, products with digital elements shall be made available on the market **without known exploitable vulnerabilities;**

**Annex I Part II point (2):** manufacturers of products with digital elements shall in **relation to the risks posed to products** with digital elements, **address and remediate vulnerabilities without delay**, including by providing security updates; where technically feasible, new security updates shall be provided separately from functionality updates;

**EUCC Implementing Act**

**Attack potential calculation:** the comparison of the Attack Potential Calculation results against the assurance level of the security certificate is one form of risk-based management of vulnerabilities.

**Criteria to assess the risk:** for example, the vulnerability is proven to exploited, it is publicly known that the vulnerability is exploited.

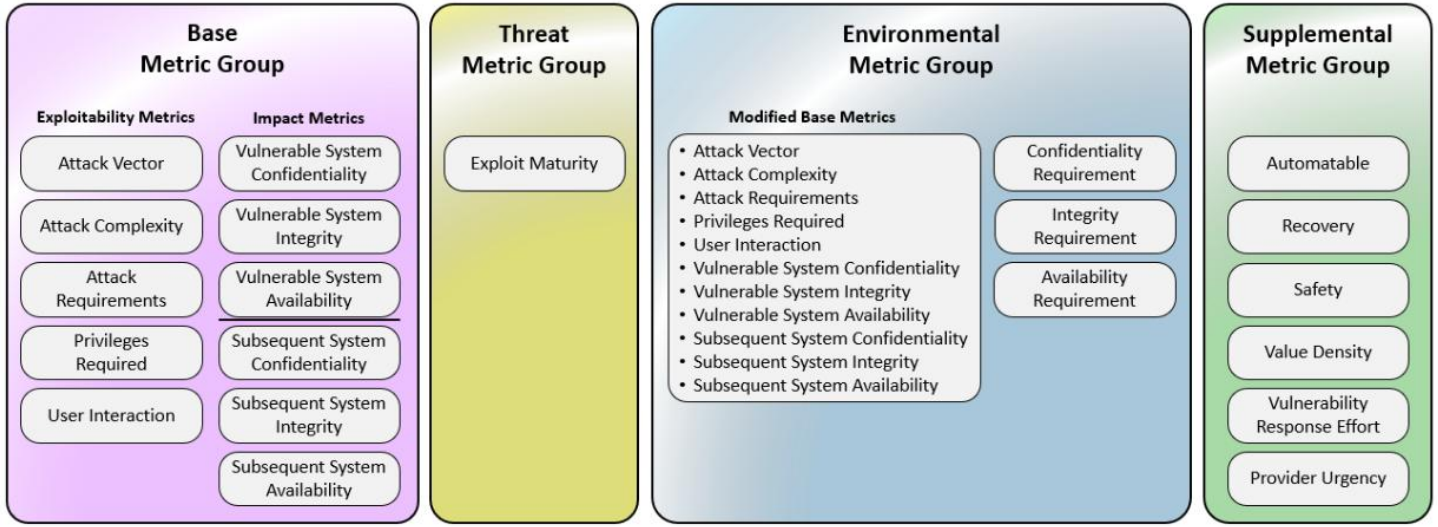
TLP:CLEAR

# CVSS 4.0: CVSS Base (CVSS-B) scores should not be used alone to assess risk

## They are designed to measure the severity of a vulnerability

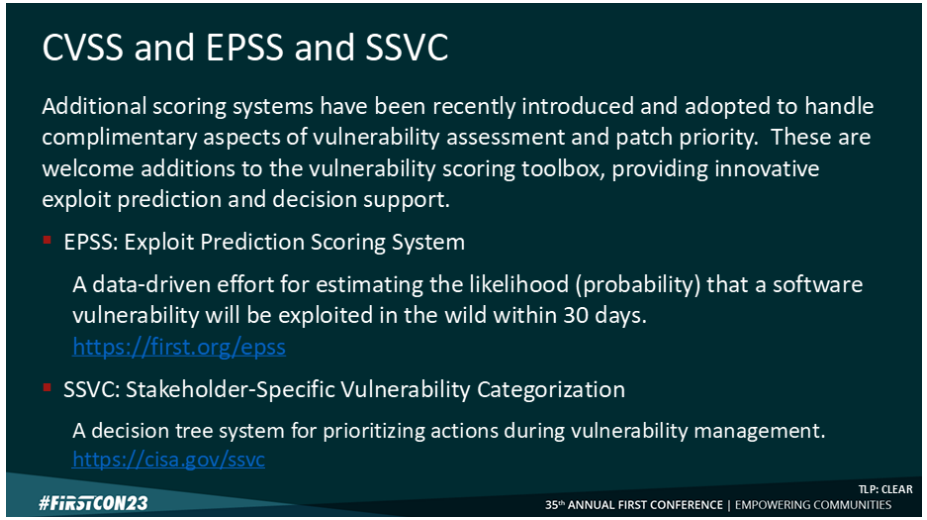
***Base Metrics, and optionally Supplemental Metrics**, are provided by the organization maintaining the vulnerable system, or a third party assessment on their behalf. **Threat and Environmental information** is available to only the end consumer. Consumers of CVSS should enrich the Base metrics with Threat and Environmental metric values specific to their use of the vulnerable system to produce a score that provides a more comprehensive input to risk assessment specific to their organization. Consumers may use CVSS information as input to an organizational vulnerability management process that **also considers factors that are not part of CVSS in order to rank the threats to their technology infrastructure and make informed remediation decisions**. Such factors may include, but are not limited to: regulatory requirements, number of customers impacted, monetary losses due to a breach, life or property threatened, or **reputational impacts of a potential exploited vulnerability**. These factors are outside the scope of CVSS.*

*Source: https://first.org/cvss/specification-document*




2.2. CVSS Base Score (CVSS-B) Measures Severity, not Risk

*Source: https://www.first.org/cvss/v4.0/user-guide*




*Source: https://www.first.org/cvss/v4-0/cvss-v40-presentation.pdf*

**CVSS 4.0 lacks support for vulnerability risk assessment and prioritization decisions, other technologies are still needed. This is why risk assessment methods are widely used in Huawei and the industry.**

# Huawei proposes a new Vulnerability Risk Assessment Model

**Objectives of the model**

**Address the vulnerability challenge:** scale with year-on-year increase of discovered vulnerabilities and vulnerability corpus

**Address regulatory requirements**, for example

- Cover CRA requirements (no known exploitable vulnerabilities, report actively exploited vulnerabilities)
- Can be used to scope attack potential calculation in the EUCC

RED CRA NIS2 Imp. Act EUCC …

**Support regulatory/certification vulnerability management requirements**

**Vulnerability Risk** = **Vulnerability exploitation (likelihood)** × **Vulnerability impact (impact)**




- **Vulnerability exploitation (likelihood)**
  - Exploitation
  - Exposed to untrusted environments
- **Vulnerability impact (impact)**
  - Technical impact — Vendor
  - Business impact — Vendor & Customers

**The Model and values should be adapted to different industries**

IT ICT Cloud Consumer devices OT …

TLP:CLEAR



# CONTENTS


01. Vulnerability Risk Assessment

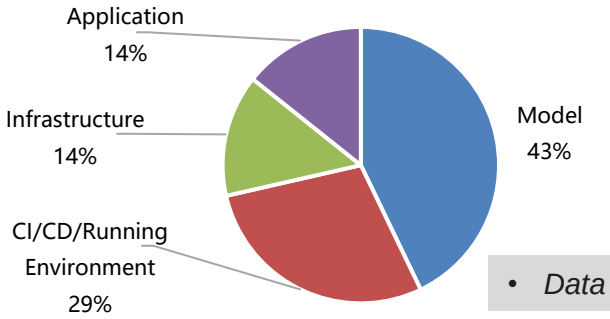
02 . AI Vulnerability Assessment

03 Takeaway and Next Step

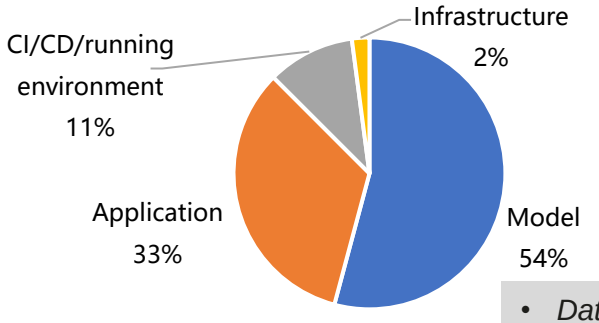
# AI system security vulnerabilities have already emerged

## The nature of AI system vulnerabilities pose multiple challenges for end-to-end response and governance

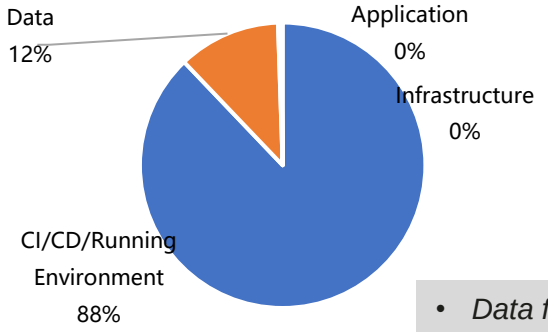
### AI Vulnerability Data Analysis from different organizations 'data




- *Data from：CERT/CC*




- *Data from： OWASP*




- *Data from：Huntr*

### Example Vulnerability / Attack

**Application**

**Remote Code Execution**

CVE-2024-12433

**Model**

**Prompt Injection (leading to RCE)**

CVE-2024-5565

**Infrastructure**

**Deserialization Vulnerability**

CVE-2024-48063

**Data**

**Data Poisoning**

"Poisoning Web-Scale Training Datasets is Practical"

*Source https://arxiv.org/abs/2302.10149*

...

### Challenge

**Defining boundaries is difficult**
The robustness of AI systems, content security, and other aspects intersect with cybersecurity.

↓

**Risk assessment is challenging**
Beyond CIA (Confidentiality, Integrity, Availability), it also involves safety, ethics, societal impacts, etc.

↓

**Difficulty in Positioning and Traceability**
Involves the responsibility boundaries between models, datasets, manufacturers, and users.

↓

**Challenges in Patching**
Some vulnerabilities in training data and models cannot be completely fixed and can only be mitigated.

TLP:CLEAR

# AI system security vulnerabilities require to go beyond the traditional CIA framework

## The assessment of AI vulnerabilities should consider safety and other impact, industry standards should be refined

**Challenge**
There is still a lack of industry consensus on the definition and assessment of AI vulnerabilities

**Viewpoint**
Adopt the CVSS framework and expand its CIA (Confidentiality, Integrity, Availability) security dimensions and evaluation metrics

**Is the impact on safety considered when using data and models?**

**Vulnerability definition**

- May be exploited to undermine the system's security policies.
- Negative impacts on confidentiality, integrity, or availability **(CIA)**



**Data** **Model**

**Safety impacts**

**...**

*Data assumes the role of code*

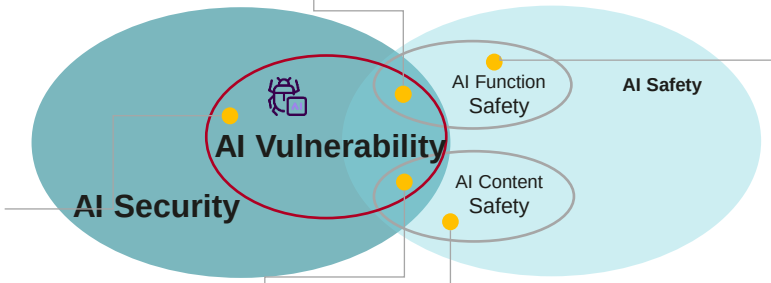
*Algorithmic black boxes are not explainable*

**Data** **Model**

**AI system security vulnerabilities fall under the domain of AI Security.**

Safety risks arise from AI system malfunctions caused by security attacks. Example:
- adversarial samples can cause autonomous driving systems to misidentify traffic signs, leading to personal injury.

Functional issues in AI systems due to internal faults or incorrect factors also pose safety risks. Example:
- erroneous predictions by AI systems can result in flawed decision-making.




Security attacks causing AI systems generating unsafe content, such as biased material or discriminatory statements

AI system failures or incorrect factors causing the AI system to generate unsafe content, such as biased content or discriminatory statements generated by AI.

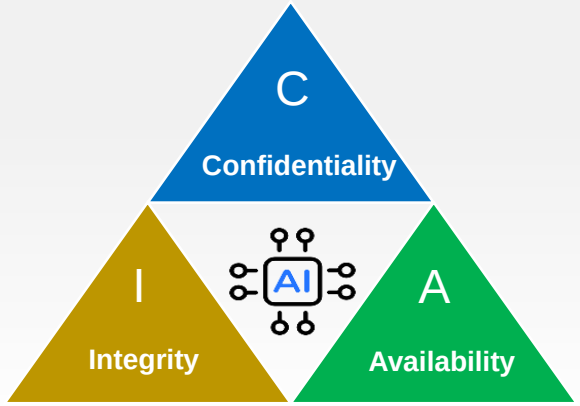
TLP:CLEAR

# Huawei understanding for the definition of AI system security vulnerabilities

**Definition**

**AI system security vulnerabilities**: an AI system security vulnerability refers to a security flaw present in the **design**, **training**, **development**, **deployment**, or **operation** of AI system (including machine learning). Once exploited by an attacker, it can bypass **security policies/mechanisms, directly impacting the confidentiality, integrity, and availability of the AI system, and causing secondary effects on personal/content safety**.

**For AI systems**




■ **Confidentiality**

Exploiting vulnerabilities can cause leaks concerning privacy, models, and data within AI models and application systems (during training). Example attack types

- data extraction (extracting training data from generative models)
- model inversion (where attackers aim to extract relevant information about the model).

■ **Integrity**

Exploiting vulnerabilities can cause unintended deviations in the predictions or decision-making processes of AI models. Example attack types

- data poisoning
- backdoor implantation
- adversarial examples (carefully designed or trained inputs aimed at causing the model to make incorrect predictions or classifications).

■ **Availability**

Exploiting vulnerabilities can cause disruption or degradation in the availability or performance of services provided by AI systems (affecting the AI systems themselves and the subsequent systems).

Example attack types

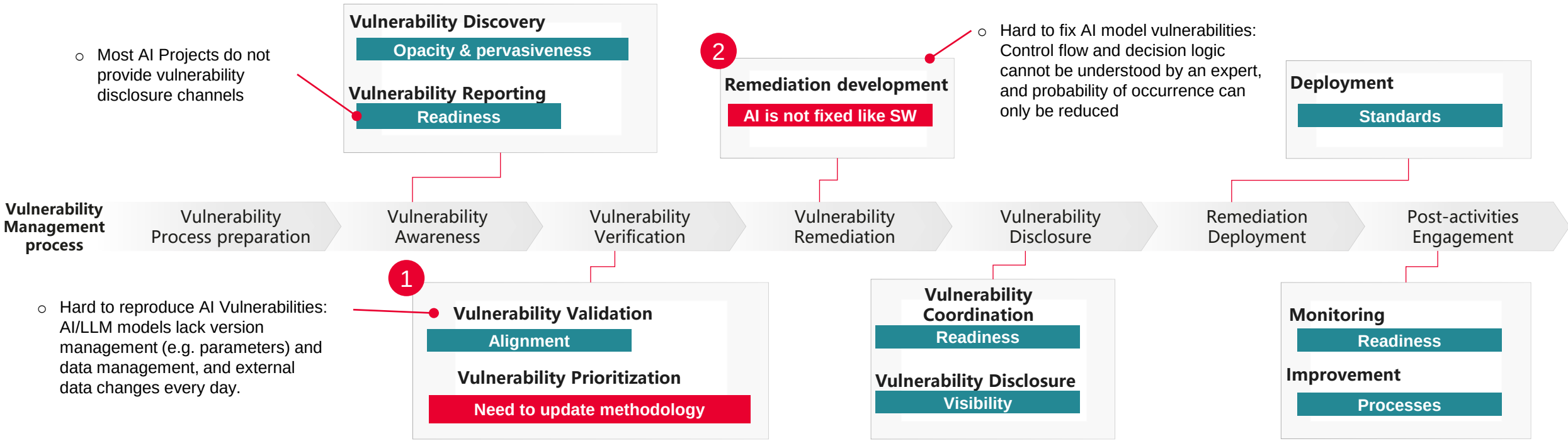
- poisoning attacks
- sponge sampling

# Looking forward: VM process should be adapted to handle AI System vulnerabilities

Traditional software Vs AI models

**Key points**

- ❑ The AI systems security vulnerabilities are exploitable flaws or weaknesses that can be introduced at any stage of AI system lifecycle, from design and training to deployment and operation
- ❑ The AI system security vulnerability assessment method should extend the assessment metrics in the CVSS framework
- ❑ Quick mitigation of AI system vulnerability is more important than remediation in some scenarios
- ❑ To ensure effective AI system security vulnerability management and reduce risk, all parties in the supply chain need to assume their responsibilities and strengthen collaboration to mitigate vulnerability risks




*Sources:*
*1. CMU SEI (CERT/CC), Protecting AI from the Outside In: The Case for Coordinated Vulnerability Disclosure, February 24, 2025*
*2. White Paper " LESSONS LEARNED IN COORDINATED DISCLOSURE FOR ARTIFICIAL INTELLIGENCE AND MACHINE LEARNING SYSTEMS", Auguis 2024, DOI: 10.1184/R1/26867038.V1*



# CONTENTS


01. Vulnerability Risk Assessment

02 . AI Vulnerability Assessment

03 Takeaway and Next Step

# Takeaway and Next Steps:

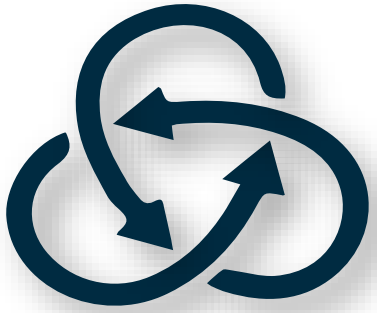
Huawei is looking forward to cooperate with the industry to explore AI system Vulnerability Management standards and practices and other related topics

## Takeaway

01 Vulnerability Risk Assessment Model

02 AI system security vulnerabilities **Definition** and **Assessment**

## Next Steps



- ✓ **Discussion and Cooperation**
- ✓ **Standardisation**

# Thank you.

Bring digital to every person, home and organization for a fully connected, intelligent world.

**Copyright©2018 Huawei Technologies Co., Ltd.**
**All Rights Reserved.**

The information in this document may contain predictive statements including, without limitation, statements regarding the future financial and operating results, future product portfolio, new technology, etc. There are a number of factors that could cause actual results and developments to differ materially from those expressed or implied in the predictive statements. Therefore, such information is provided for reference purpose only and constitutes neither an offer nor an acceptance. Huawei may change the information at any time without notice.

